

Rapport Nmap / OWASP ZAP

Projet CYNA - Tests de sécurité réseau et applicatifs

Périmètre	VLAN serveurs Genève 10.0.20.0/24 et serveur Web DMZ 10.0.30.1
Outils	Nmap, OWASP ZAP
Rédacteurs	Damien Craciun / Adam Boudaoud
Objectif	Valider les hôtes actifs, les ports exposés et l'absence de vulnérabilité applicative critique.

Objectif du rapport

Ce rapport présente les résultats des tests de sécurité réalisés dans le cadre du projet CYNA. Les tests ont été menés afin de vérifier la visibilité réseau, les ports exposés sur les services placés en DMZ et le niveau de durcissement applicatif du serveur Web Nginx.

Les contrôles portent principalement sur trois éléments : la découverte des hôtes actifs, l'analyse des ports ouverts et l'identification des mauvaises configurations HTTP à l'aide d'un scan applicatif OWASP ZAP.

Méthodologie

Étape	Commande / outil	Objectif
Découverte réseau	nmap -sn 10.0.20.0/24	Identifier les hôtes actifs dans le VLAN serveurs Genève.
Scan du serveur Web DMZ	nmap -sT -sV -Pn 10.0.30.1	Identifier les ports ouverts et les services exposés sur le serveur Nginx.
Analyse applicative	OWASP ZAP sur http://10.0.30.1	Contrôler la présence de vulnérabilités applicatives ou de mauvaises configurations HTTP.

Résultats détaillés

Test 1 - Scan de découverte du VLAN serveurs Genève

Un premier scan de découverte a été effectué depuis le serveur Windows 10.0.20.1, situé dans le VLAN serveurs Genève. L'objectif était d'identifier les équipements actifs et de valider la visibilité réseau dans cette zone.

```
nmap -sn 10.0.20.0/24
```

Le scan a permis d'identifier 9 hôtes actifs dans le VLAN serveurs Genève, dont DC01.cyna.local, DC02.cyna.local, la passerelle OPNsense 10.0.20.252 ainsi que plusieurs machines hébergées sur Proxmox.

Élément	Résultat
Réseau analysé	10.0.20.0/24
Hôtes actifs détectés	9
Équipements identifiés	DC01, DC02, OPNsense 10.0.20.252, machines Proxmox
Interprétation	La découverte réseau confirme que les principaux équipements du VLAN serveurs sont joignables.

Test 2 - Scan de ports du serveur Web en DMZ

Un second test a été réalisé sur le serveur Web Nginx placé en DMZ à l'adresse 10.0.30.1. L'objectif était d'identifier les ports exposés et les services accessibles.

```
nmap -sT -sV -Pn 10.0.30.1
```

Le résultat montre que les ports 22/tcp et 80/tcp sont ouverts. Le port 80 correspond au service Web Nginx exposé en DMZ. Le port 22 correspond à l'administration SSH et doit être limité au VLAN Management dans une configuration finale sécurisée.

Port	Service	Analyse
22/tcp	SSH	Port d'administration détecté. À restreindre au VLAN Management uniquement.
80/tcp	HTTP / Nginx	Service Web exposé en DMZ. À durcir avec des en-têtes HTTP de sécurité.

Test 3 - Analyse applicative OWASP ZAP

Un scan applicatif a été lancé avec OWASP ZAP sur l'adresse http://10.0.30.1. Ce test avait pour objectif d'identifier d'éventuelles vulnérabilités applicatives ou mauvaises configurations HTTP sur le service Web exposé en DMZ.

```
OWASP ZAP - Target: http://10.0.30.1
```

Le scan n'a pas détecté de vulnérabilité critique. En revanche, trois alertes de durcissement HTTP ont été identifiées : absence de l'en-tête Content Security Policy, absence d'un en-tête anti-clickjacking et absence de l'en-tête X-Content-Type-Options.

Alerte OWASP ZAP	Impact	Recommandation
Content Security Policy absente	Risque de réduction du contrôle sur les scripts et contenus chargés par le navigateur.	Ajouter un en-tête Content-Security-Policy adapté au service Web.
Protection anti-clickjacking absente	Possibilité d'intégrer la page dans une frame selon la configuration du navigateur.	Ajouter X-Frame-Options ou frame-ancestors dans la CSP.
X-Content-Type-Options absent	Risque d'interprétation incorrecte du type de contenu par le navigateur.	Ajouter X-Content-Type-Options: nosniff dans la configuration Nginx.

Synthèse des résultats

Test	Résultat	Statut
Découverte réseau Nmap	9 hôtes actifs détectés dans le VLAN serveurs Genève.	Validé
Scan de ports Nmap	Ports 22/tcp et 80/tcp ouverts sur le serveur Web DMZ.	Validé avec point d'amélioration
Scan OWASP ZAP	Aucune vulnérabilité critique détectée. Trois alertes de durcissement HTTP identifiées.	Validé avec corrections recommandées

Actions correctives recommandées

ID	Action	Priorité
NZ-001	Restreindre l'accès SSH du serveur Web DMZ au VLAN Management uniquement.	Haute

ID	Action	Priorité
NZ-002	Ajouter les en-têtes HTTP de sécurité sur Nginx : Content-Security-Policy, X-Frame-Options ou frame-ancestors, X-Content-Type-Options.	Moyenne
NZ-003	Maintenir une politique de filtrage stricte entre la DMZ et les réseaux internes via OPNsense.	Haute
NZ-004	Réaliser un nouveau scan Nmap et OWASP ZAP après correction afin de valider les améliorations.	Moyenne

Conclusion

Les tests réalisés confirment que les principaux équipements du VLAN serveurs sont joignables, que le serveur Web Nginx est bien exposé en DMZ et que l'analyse OWASP ZAP ne remonte pas de vulnérabilité critique. Les points d'amélioration concernent principalement le durcissement HTTP du serveur Nginx et la restriction de l'accès SSH au VLAN Management.

Ce rapport complète les preuves de détection Wazuh et permet de documenter les contrôles réseau et applicatifs réalisés sur l'infrastructure CYNA.